UNIT 4 · TOPIC 4.2

Authentication

Quiz, Answer Key

Teacher answer key, 18 questions, 1 point each. The correct answer is highlighted; the explanation and distractor notes follow.

1. A system administrator stores user credentials in a database. Which of the following best identifies the primary purpose of hashing passwords before storing them?

- ○ A. To encrypt the password so that the administrator can decrypt and view it when needed.
- ○ B. To compress the password string in order to reduce database storage costs.
- **● C. To produce a fixed-length value that cannot feasibly be reversed to reveal the original password.**
- ○ D. To convert the password to Base64 encoding for safe transmission over a network.

Correct answer: C

Why: Hashing is a one-way function that transforms a password into a fixed-length digest. Because it is computationally infeasible to reverse, even if the database is breached, the original passwords are not directly exposed. This is a preventive control that mitigates the risk of credential theft from stored data. Encryption (A) is two-way and requires a key; Base64 (D) is encoding, not a security control; compression (B) offers no security benefit.

*Why the others are wrong: **A**, Encryption is reversible with the correct key, students often conflate hashing with symmetric encryption. If the database owner could decrypt passwords, so could an attacker who also obtained the key. **B**, Hashing does produce a fixed-length output, which may appear to "compress" long passwords, but the purpose is integrity and one-way transformation, not storage efficiency. **D**, Base64 is an encoding scheme with no secrecy, any party can decode it. Students may confuse encoding with cryptographic protection.*

2. Which of the following best identifies an example of multi-factor authentication (MFA)?

- **● A. A user enters a password and then approves a push notification on a registered smartphone.**
- ○ B. A user enters a password and then answers a security question.
- ○ C. A user enters a username and a password.
- ○ D. A user enters two different passwords on two successive login screens.

Correct answer: A

Why: MFA requires credentials from two or more distinct factor categories: something you know, something you have, or something you are. A password (knowledge factor) combined with a smartphone push approval (possession factor) satisfies this requirement. Choice C uses only one factor. Choice B combines two knowledge factors (both "something you know"), which does not constitute MFA. Choice D also uses only the knowledge factor twice.

*Why the others are wrong: **B**, A common misconception: security questions feel like a second step but belong to the same category (knowledge) as the password, making this single-factor authentication. **C**, A username identifies the user but is not a credential factor; the password is only one factor. This is single-factor authentication. **D**, Using two passwords is still single-factor (both knowledge). The distinction between multi-step and multi-factor is a frequent source of confusion.*

3. Which of the following authentication credentials is classified as a "something you are" factor?

- **● A. A fingerprint scan.**
- ○ B. A hardware security token that generates one-time codes.
- ○ C. A one-time passcode sent to a registered mobile phone via SMS.
- ○ D. A personal identification number (PIN).

Correct answer: A

Why: Authentication factors are categorized as something you know (knowledge), something you have (possession), or something you are (inherence/biometrics). A fingerprint is a biometric attribute inherent to the user's physical person, making it a "something you are" factor. A PIN (D) is knowledge; a hardware token (B) and an SMS code (C) are possession factors, since both depend on a physical device the user holds.

*Why the others are wrong: **B**, A hardware token is a physical object the user carries, a possession factor. Its output codes change every 30 seconds but still require possessing the device. **C**, SMS codes depend on possession of the registered phone. The code itself is not unique to the user's biology. **D**, A PIN is a memorized secret, a knowledge factor, not biometric. Students often equate "short password" with "biometric" because both seem tied to the person.*

4. An attacker breaches a web application's database and obtains the stored password records. The application stores passwords as bcrypt hashes. Which of the following best explains why hashing reduces the impact of this breach compared to storing plaintext passwords?

○ A. The bcrypt hashes are automatically re-encrypted on each database read, so the attacker's copy becomes invalid immediately after the breach.

○ B. Bcrypt hashes are protected by the database server's private key, preventing the attacker from reading them without that key.

● C. The attacker cannot use the hash values directly to authenticate and must attempt computationally expensive offline cracking to recover any original passwords.

○ D. The hashes allow the organization to immediately identify which accounts were compromised because each hash is unique to one user.

Correct answer: C

Why: Hashing transforms the password into a one-way digest. Even with the hash in hand, the attacker cannot log in by submitting the hash (authentication systems hash the input and compare, submitting a raw hash would itself be hashed again, yielding a non-match). Recovery requires brute-forcing or dictionary attacks against each hash. Bcrypt is intentionally slow (configurable cost factor), making this computationally expensive. None of A, C, or D reflect how hashing or bcrypt actually work.

*Why the others are wrong: **A**, Bcrypt hashes are static values; they do not re-encrypt dynamically. This confuses hashing with some form of ephemeral token system. **B**, Bcrypt is not an asymmetric encryption scheme. It uses a key-stretching algorithm with a salt, not a private key. **D**, While with salted hashes each user's hash is indeed distinct, the statement misidentifies this as the primary security benefit of hashing, the real benefit is one-way transformation, not account identification.*

5. At Aceshack, a junior sysadmin configures the shared drop-in workstation to lock an account after five consecutive failed login attempts. Which of the following best explains how this setting mitigates an online brute-force password attack?

● A. It limits the number of guesses an attacker can make before access is blocked, making exhaustive trial-and-error impractical without triggering a lockout.

○ B. It encrypts the account's credentials after five failures, making them unreadable until an administrator unlocks the account.

○ C. It forces the attacker to switch to a different authentication protocol after five failed attempts, increasing the complexity of the attack.

○ D. It resets the account password automatically after five failures and sends a new credential to the account owner.

Correct answer: A

Why: Account lockout is a preventive control that interrupts online brute-force attacks by imposing an attempt ceiling. After the threshold is reached, the attacker's guessing process is blocked regardless of whether they would eventually guess the correct password. The control does not encrypt credentials (B), redirect to another protocol (C), or reset the password (D), it simply denies further authentication attempts until the lockout is resolved.

*Why the others are wrong: **B**, Credential encryption is a separate storage-layer control unrelated to lockout policy. Lockout does not modify how credentials are stored. **C**, Authentication protocols are not switched mid-session by lockout policies. This confuses lockout with protocol negotiation. **D**, Automatic password resets are a distinct account recovery mechanism, not a feature of lockout policies, and would introduce its own security risks if triggered by any attacker-controlled failure sequence.*

6. Aceshack is evaluating whether to require MFA on the shared drop-in workstation used by visiting remote workers. A manager asks why MFA would still be valuable even if a worker's password is already strong. Which of the following best explains MFA's risk-reduction benefit in this scenario?

○ A. MFA prevents password reuse across sites, ensuring a compromised password on one system cannot be used on another.

● B. MFA requires an attacker to also control a second authentication factor, such as the user's phone or hardware token, which the attacker is unlikely to possess even if they have obtained the password.

○ C. MFA completely replaces the password with a stronger credential, removing the risk associated with password-based authentication.

○ D. MFA encrypts all traffic between the workstation and Aceshack's servers, preventing credential interception in transit.

Correct answer: B

Why: MFA's core security benefit is that a compromised password alone is no longer sufficient for unauthorized access. The attacker must additionally compromise a separate factor category, possession or biometric, which is typically much harder to steal remotely. MFA does not enforce cross-site password policies (A), replace the password entirely (C, which would be single-factor biometric or token), or function as a transport-layer encryption mechanism (D).

*Why the others are wrong: **A**, Password reuse prevention is a function of password managers, breach-detection services, or organizational policy, not of MFA itself. MFA adds a factor; it does not regulate where passwords are reused. **C**, Most MFA implementations add a factor rather than replace the password. Removing the password would make it single-factor again (just a different factor). **D**, Transport encryption (e.g., TLS) is a separate network-layer control independent of the number of authentication factors.*

7. A financial services firm uses hashed and salted passwords, enforces account lockout after three failed attempts, and requires SMS-based MFA for all employee logins. During a recent red-team exercise, testers demonstrated that SIM-swapping attacks could allow an adversary to intercept SMS codes. Which of the following best evaluates the firm's current authentication posture and identifies the most effective remediation?

○ A. The firm's controls are sufficient; bcrypt hashing and salting protect against all realistic attack vectors, including SIM-swapping.

○ B. The account lockout threshold of three attempts is too permissive; raising it to ten would eliminate the SIM-swapping vulnerability.

○ C. The firm should discontinue MFA and invest those resources in stronger minimum password length requirements and more frequent mandatory rotations.

● D. SMS-based MFA is susceptible to SIM-swapping; replacing it with a phishing-resistant alternative, such as a TOTP authenticator app or a FIDO2 hardware key, preserves the layered approach while closing the demonstrated gap.

Correct answer: D

Why: NIST SP 800-63B classifies SMS-based authentication as "restricted" in part because of real-world SIM-swapping incidents, where attackers social-engineer carriers to redirect a victim's phone number. TOTP apps (e.g., TOTP per RFC 6238) or FIDO2 hardware keys are bound to a physical device or cryptographic key that cannot be redirected through a carrier, directly neutralizing SIM-swapping. Hashing and salting (A) protect stored credentials, a different attack surface. Adjusting the lockout threshold (B) has no bearing on a successful MFA bypass. Removing MFA (C) weakens the overall posture by reducing factor diversity.

*Why the others are wrong: **A**, Hashing protects at-rest passwords, not live authentication sessions. It does not defend against a scenario where the attacker intercepts a valid second-factor code. **B**, Account lockout counters repeated failed attempts; SIM-swapping succeeds in obtaining a legitimate code on the first attempt, never triggering lockout. **C**, Password length requirements address a different threat model (password guessing). Removing MFA downgrades the system from two-factor to single-factor, increasing overall risk.*

8. Two web applications are breached simultaneously and their password databases stolen. Application Kappa stored passwords as unsalted MD5 hashes. Application Lambda stored passwords using bcrypt with a unique per-

user random salt. Which of the following best evaluates the relative exposure of each application's users, and explains why?

- **● A. Lambda's users are at significantly lower risk, because unique salts defeat precomputed rainbow tables and bcrypt's tunable cost factor makes offline brute-force computationally expensive even for modern hardware.**
- ○ B. Kappa's users are equally exposed, because MD5 and bcrypt are both one-way hashing algorithms, making reversal impossible regardless of salting.
- ○ C. Kappa's users are more secure because MD5 produces a shorter hash than bcrypt, which requires less storage and is therefore harder to target.
- ○ D. Both applications are equally vulnerable because all password hashes can eventually be reversed using quantum computing, negating any benefit from salting or algorithm choice.

Correct answer: A

Why: Unsalted MD5 is doubly problematic: MD5 is extremely fast (billions of hashes per second on consumer GPUs), and without salts, identical passwords produce identical hashes, enabling precomputed rainbow table attacks that can crack common passwords instantly. Bcrypt was specifically designed for password hashing: its work factor is tunable (slowing brute-force with Moore's law), and per-user salts ensure that even identical passwords produce distinct digests, nullifying precomputed tables. Per NIST SP 800-132, memory-hard or iterative key-derivation functions (bcrypt, Argon2, scrypt) are recommended precisely for this reason.

*Why the others are wrong: **B**, While both are one-way, "impossible to reverse" ignores dictionary attacks, brute-force, and precomputed tables, all of which are realistic against MD5. The feasibility of reversal depends heavily on the algorithm's speed and salting. **C**, Hash length is not a security property that protects stored passwords. MD5's 128-bit output does not provide meaningful resistance against brute-force compared to bcrypt's intentional slowness. **D**, Quantum computing currently offers theoretical (Grover's algorithm) speedup against symmetric key search, halving effective key length, but does not make practical password hash reversal a near-term threat. This choice overstates quantum risk to avoid a concrete analysis of current controls.*

9. A hospital security team must design authentication controls for clinical workstations shared by nurses across a shift. Requirements include: rapid re-authentication after brief inactivity (to avoid delays in patient care), prevention of unauthorized access if a nurse steps away, and protection if a visitor observes a nurse entering credentials. Which configuration best balances these competing requirements?

- ○ A. A complex 16-character password with a 30-minute inactivity lockout and no MFA.
- **● B. A badge tap (possession factor) plus a short PIN (knowledge factor), with a 3-minute inactivity screen lock.**
- ○ C. No password; rely entirely on physical access controls to the ward to prevent unauthorized use.
- ○ D. Fingerprint biometric only, with a 60-minute inactivity lockout.

Correct answer: B

Why: The scenario demands fast authentication (eliminating long passwords as the sole factor), short re-authentication windows (eliminating 30- or 60-minute lockouts), and resistance to shoulder-surfing (a visible PIN is partially mitigated when paired with a physical badge that the observer cannot also steal easily). Badge + PIN provides two-factor authentication from two distinct categories, re-authentication is rapid (tap + 4-digit PIN), and a 3-minute lockout limits exposure during brief absences. Choice A uses single-factor with a long lockout, leaving extended unauthorized access windows. Choice C eliminates authentication entirely. Choice D uses single-factor biometric with a dangerously long lockout for a shared clinical environment.

*Why the others are wrong: **A**, A 30-minute window leaves an unattended workstation fully accessible. A complex password also slows re-authentication, conflicting with patient-care responsiveness requirements. **C**, Physical access controls to a ward cannot substitute for workstation authentication, porters, cleaning staff, visitors, and other non-clinical personnel may have legitimate reasons to enter the ward without needing workstation access. **D**, A 60-minute lockout is far too permissive in a shared clinical environment where nurses leave workstations frequently. Single-factor biometric also provides no protection if the biometric sensor is fooled or malfunctions.*

10. Which of the following best identifies the defining characteristic of a "layered" authentication approach?

- ○ A. Storing multiple copies of a user's password hash across separate servers to prevent data loss.

● **B. Requiring credentials from two or more distinct factor categories so that compromising one layer alone is insufficient to gain access.**

○ C. Asking a user to authenticate through the same credential type twice in succession during a single session.

○ D. Distributing authentication requests across multiple servers to improve login performance.

Correct answer: B

Why: Layered (defense-in-depth) authentication means combining controls from different categories, knowledge, possession, and inherence, so that an adversary must defeat multiple independent barriers to succeed. Redundant hash storage (A) is a data-availability measure, not authentication layering. Authenticating twice with the same factor type (C) adds a step but not an additional security layer. Load-balancing authentication servers (D) addresses availability, not security depth.

*Why the others are wrong: **A**, Data redundancy protects availability of the credential store but does not change how authentication is verified or how many factors are required. **C**, Two knowledge-factor steps (e.g., password then security question) are still single-factor in category, a common misconception about what "multi-factor" means. **D**, Authentication server redundancy is an infrastructure resilience concept unrelated to the number or diversity of authentication factors.*

11. A system administrator wants to address two distinct vulnerabilities: (1) stolen hashed passwords from a breached database and (2) online brute-force guessing of active accounts. Which combination of controls directly targets both vulnerabilities?

○ A. Mandatory password complexity rules and a frequent password rotation schedule.

○ B. Intrusion detection logging and physical access controls to the server room.

○ C. MFA and a 90-day password expiration policy.

● **D. Password hashing with unique salts (to protect stored credentials) and account lockout (to block excessive login attempts).**

Correct answer: D

Why: Each vulnerability requires a separate targeted control: salted hashing addresses the stored-credential breach by making hash reversal expensive and defeating rainbow tables; account lockout addresses online brute-force by capping the number of guess attempts. Complexity and rotation (A) improve password quality but do not protect already-stolen hashes or directly stop online guessing. MFA (C) adds a second factor but does not directly protect at-rest hashes. Logging and physical controls (B) are detective and preventive controls for different threat surfaces.

*Why the others are wrong: **A**, Complexity rules affect the difficulty of guessing the password; they do not protect a hash that has already been stolen, nor do they stop an attacker from making unlimited online attempts without a lockout policy. **B**, IDS logging detects intrusion after the fact and physical access controls protect a different attack surface. Neither directly mitigates online guessing or hash theft. **C**, MFA is an excellent compensating control, but it does not change how passwords are stored. A breached database still exposes weakly hashed passwords regardless of MFA configuration.*

12. A system is configured to lock an account after five failed login attempts and to notify the account owner via email when a lockout occurs. Which type of password attack does this control combination most directly address?

● **A. An online brute-force attack attempting many password guesses against a live login interface.**

○ B. A pass-the-hash attack targeting cached NTLM credentials.

○ C. A rainbow table attack against a stolen password database.

○ D. A credential stuffing attack using one known password attempted against many different user accounts.

Correct answer: A

Why: Online brute-force attacks operate by submitting many password guesses to a live authentication interface. Account lockout directly interrupts this by blocking the account after the threshold is exceeded; the email notification provides a detection signal to the legitimate user. Rainbow table attacks (C) target at-rest stored hashes and are unaffected by lockout. Pass-the-hash (B) bypasses password authentication entirely by replaying hash values, so lockout on plaintext

attempts does not apply. Credential stuffing (D) is designed specifically to stay under lockout thresholds by attempting only one or two passwords per account, using verified breached credentials.

*Why the others are wrong: **B**, Pass-the-hash exploits authentication protocols directly using a hash token rather than submitting a password to the normal login interface, bypassing lockout conditions entirely. **C**, Rainbow table attacks occur offline against a stolen database, lockout policies only govern live authentication sessions and have no effect on offline hash cracking. **D**, This is a nuanced but important distinction: credential stuffing attackers specifically limit attempts per account to avoid lockout. Lockout alone is an insufficient defense against credential stuffing, which is why MFA and anomalous-login detection are also recommended.*

13. You are the junior sysadmin at Aceshack, configuring a new shared workstation in the lobby drop-in area used by visiting remote workers throughout the day. The workstation is left unattended between users. Which combination of local security settings best addresses both unauthorized access from the unattended workstation and password-based attacks against user accounts?

○ A. Disable account lockout to prevent legitimate remote workers from being locked out; do not enable MFA to keep login simple.

● B. Account lockout after five failed attempts, minimum password length of 12 characters, and automatic screen lock after 10 minutes of inactivity.

○ C. Account lockout after 20 failed attempts and no screen lock, to reduce disruption for legitimate users who share the workstation.

○ D. Mandatory password rotation every seven days and no lockout policy, relying on complex passwords alone to deter unauthorized access.

Correct answer: B

Why: Three distinct risks converge on a shared unattended workstation: online password guessing (mitigated by lockout after five attempts), weak passwords susceptible to dictionary attacks (mitigated by a 12-character minimum), and physical opportunistic access when a user steps away (mitigated by automatic screen lock). Choice B deploys a layered control set targeting each risk. A (no lockout, no MFA) removes a key preventive control. C's high lockout threshold of 20 allows substantial brute-force before triggering; the absent screen lock is a significant physical-access gap. D's rotation-only approach does not stop online guessing without a lockout.

*Why the others are wrong: **A**, Disabling lockout removes protection against brute-force attacks entirely. Simplicity is a usability consideration, but it should not override core security controls on a shared, publicly accessible workstation. **C**, A 20-attempt threshold provides meaningful room for a dictionary or brute-force attack before triggering. Without screen lock, anyone who approaches the machine while a session is active can access it without authentication. **D**, Password rotation alone does not reduce the risk of an attacker making unlimited guesses against the current password. Without lockout, an attacker has no imposed ceiling on attempts.*

14. An attacker purchases a list of verified username-and-password pairs from a previous breach at another organization. They attempt to use these credentials on a company's employee portal, deliberately submitting only one login attempt per account to avoid triggering lockout. Which combination of controls would most effectively neutralize this specific attack?

○ A. Account lockout after three failed attempts and a password complexity requirement of at least 10 characters.

○ B. Extended minimum password length and mandatory password expiration every 60 days.

● C. MFA requiring a second factor for all logins, combined with anomalous-login alerting based on new device or geographic location.

○ D. An intrusion detection system configured to alert on any failed login attempts.

Correct answer: C

Why: This describes a credential stuffing attack, which exploits valid stolen credentials, meaning the password is correct and will succeed on the first attempt. Account lockout (A) is irrelevant because the attacker never fails. MFA ensures that possessing the correct password is insufficient: the attacker also needs the second factor (phone, token), which they do not have. Anomalous-login detection provides a detection layer for the cases where the attacker does authenticate successfully. Password length/expiration (B) cannot help if the credential in the attacker's list matches the current password. IDS alerting on failed logins (D) provides no signal for successful unauthorized logins that use correct credentials.

*Why the others are wrong: **A**, Account lockout requires failed attempts to trigger. Since credential stuffing uses the correct password on the first attempt, there are no failures to lock out, this control does not apply to this attack pattern. **B**, If the user's current password happens to match the one in the attacker's list, expiration and length requirements are irrelevant for the current authentication cycle. The attacker succeeds before any rotation occurs. **D**, IDS alerts on failed login attempts would miss successful unauthorized logins. This is a detective control, not a preventive one, and it targets the wrong signal for this attack type.*

15. A security team identifies that a local web application is vulnerable to dictionary attacks, attackers can submit large numbers of common-word password guesses through the login form. Which combination of controls would most effectively reduce this vulnerability by targeting both the attacker's ability to attempt guesses and the likelihood that any guessed word matches a user's password?

○ A. Regular user security awareness training and a mandatory annual password reset.

○ B. Blocking remote access to the login page so that it is only accessible from the internal network.

○ C. Server-side AES-256 encryption of all stored password hashes.

● D. Password complexity requirements that reject dictionary words and common patterns, combined with account lockout after a defined number of failed attempts.

Correct answer: D

Why: A dictionary attack has two exploitable conditions: the ability to submit many guesses, and passwords that appear in dictionary wordlists. Complexity requirements target the second condition by requiring character variety that most dictionary words lack, reducing the probability that any wordlist entry matches a valid password. Account lockout targets the first condition by imposing an attempt ceiling. Together they address the attack from both angles. Awareness training (A) may influence behavior over time but is not a technical control. AES encryption of hashes (C) is a storage-layer control irrelevant to an online attack against the login form. Restricting access (B) reduces the attack surface but does not eliminate the vulnerability for users on the internal network or VPN, and does not improve password strength.

*Why the others are wrong: **A**, Training is a valuable administrative control but does not reliably prevent users from choosing weak passwords, and it does not limit how many guesses an attacker can submit to the login form. **B**, Restricting to the internal network reduces exposure but assumes no insider threat and that internal network access is tightly controlled. It does not fix the underlying vulnerability, weak passwords and unlimited guessing attempts, for anyone with internal access. **C**, Encrypting hashes adds a layer to at-rest storage protection but has no bearing on a live online attack. The attacker is submitting guesses to the login form, not querying the database directly.*

16. A company's authentication policy specifies: (1) minimum 8-character passwords, (2) account lockout after 10 failed attempts, (3) SHA-1 password hashing with no salting. A security auditor flags this as insufficient. Which of the following best evaluates the most critical weakness in this layered policy and explains why it undermines the other controls?

● A. Unsalted SHA-1 hashing is the most critical weakness, its speed enables billions of guesses per second offline, and the absence of salts makes precomputed rainbow tables effective, rendering the complexity and lockout controls meaningless if the database is breached.

○ B. The 8-character minimum is the critical weakness; raising it to 16 characters alone would resolve all identified deficiencies.

○ C. The lockout threshold of 10 is the primary weakness; reducing it to two would resolve the dominant vulnerability in this policy.

○ D. The absence of a mandatory password expiration schedule is the most critical missing control, as credentials never become invalid over time.

Correct answer: A

Why: The lockout and complexity controls address online attacks against the live login interface. However, if an attacker breaches the database, they bypass the login interface entirely and attack the hashes offline, where lockout and complexity requirements provide no protection. Unsalted SHA-1 is vulnerable on two fronts: SHA-1 was not designed as a password hashing function and produces hashes extremely quickly (enabling brute-force at enormous scale on modern GPUs), and the lack of salts means identical passwords share hashes, enabling precomputed rainbow table lookups. Per

NIST SP 800-132, slow iterative algorithms (bcrypt, PBKDF2, Argon2) with unique salts are required. Password length (B) and lockout threshold (C) are valuable but secondary. Password expiration (D) is no longer recommended as a routine policy by NIST SP 800-63B because it often leads to predictable, weaker rotated passwords.

*Why the others are wrong: **B**, Password length improves resistance to brute-force but does not address the rainbow-table vulnerability from absent salts or the speed vulnerability of SHA-1. An attacker with a precomputed table for 8-character unsalted SHA-1 hashes would still crack many passwords instantly. **C**, A lower lockout threshold strengthens online attack prevention but has no effect on offline hash cracking. The auditor's concern is that a database breach would expose credentials despite the online controls. **D**, NIST SP 800-63B explicitly recommends against forced periodic password changes unless evidence of compromise exists, noting they often result in weaker predictable passwords (e.g., Password1 → Password2).*

17. A corporate network's authentication policy includes: (1) bcrypt-hashed passwords with unique salts, (2) account lockout after five failed attempts, (3) SMS-based MFA for remote access only, (4) on-site workstations exempt from MFA. A penetration tester demonstrates that physical access to the office building, obtainable through tailgating, allows full system access without MFA. Which modification best closes this gap while maintaining the defense-in-depth approach?

○ A. Remove SMS-based MFA from remote access and rely solely on bcrypt hashing and lockout policies for all access.

○ B. Install CCTV surveillance cameras at all on-site workstations to deter unauthorized physical access.

○ C. Upgrade SMS MFA to a TOTP authenticator app for remote access only; no change to on-site exemption is needed.

● D. Extend MFA to all access contexts, both on-site and remote, so that physical presence in the building is not sufficient to bypass the second authentication factor.

Correct answer: D

Why: The demonstrated gap is that the on-site MFA exemption creates a single-factor authentication path exploitable by anyone who gains physical building access. Defense-in-depth requires that no single failure (here: perimeter physical access) grants full system access. Extending MFA universally removes the MFA-exempt path entirely, restoring the requirement for two independent factors regardless of access location. Choice A reduces overall security by removing MFA from remote access. Choice C improves the MFA mechanism for remote access but leaves the on-site exemption gap open, the identified vulnerability is the exemption, not the type of MFA used remotely. Choice B is a detective/deterrent physical control that does not prevent unauthorized authentication if physical access is already obtained.

*Why the others are wrong: **A**, Removing MFA from remote access reduces the system to single-factor for the highest-risk access mode (remote). This directly worsens the posture rather than addressing the identified gap. **B**, Surveillance deters and detects but does not prevent authentication. An attacker who tailgates successfully can still authenticate with a single factor at an on-site workstation while being filmed. **C**, Upgrading from SMS to TOTP is a worthwhile improvement in MFA strength, but the penetration tester's finding specifically concerned the on-site exemption, not the choice of remote MFA mechanism. Fixing only the mechanism leaves the gap untouched.*

18. As junior sysadmin at Aceshack, you receive the following authentication requirements from the security manager for the shared drop-in workstation: (a) multiple authorized remote workers must each maintain individual accountability, (b) legitimate users accidentally locked out must be recoverable without a full support ticket, (c) a visitor who learns a worker's password must still not be able to log in, (d) the solution must align with NIST SP 800-63B guidance. Which combination of controls best satisfies all four requirements simultaneously?

○ A. A single shared generic account with a complex password rotated weekly; no lockout policy to prevent service disruption.

○ B. Individual user accounts with SMS-based MFA only, no lockout policy, and mandatory 30-day password expiration.

● C. Individual user accounts with bcrypt-hashed passwords, account lockout with a self-service unlock option, and TOTP-based MFA (e.g., an authenticator app).

○ D. A shared generic account with fingerprint biometric authentication and a 20-attempt lockout threshold.

Correct answer: C

Why: Requirement (a) mandates individual accounts, ruling out A and D which use shared accounts, making individual accountability impossible. Requirement (b) is addressed by self-service account unlock (e.g., via a verified secondary email or manager approval), avoiding the need for a full ticket while still controlling who can unlock. Requirement (c) is met by TOTP MFA, a visitor with only the password still lacks the second factor generated by the individual's authenticator app. Requirement (d): NIST SP 800-63B recommends phishing-resistant or verifier-impersonation-resistant authenticators; TOTP is acceptable at AAL2, and bcrypt satisfies memorized secret requirements. SMS MFA (B) is classified as "restricted" under NIST 800-63B due to SIM-swapping risk and may not satisfy a strict reading of requirement (d). Mandatory 30-day expiration also conflicts with NIST 800-63B, which recommends against routine expiration unless compromise is suspected.

*Why the others are wrong: **A**, A shared account makes individual accountability impossible, if a security incident occurs, audit logs cannot identify which worker took which action. It also fails requirement (c) since any visitor who observes the password can log in. **B**, No lockout policy leaves accounts open to unlimited online guessing. SMS MFA is NIST-restricted and may not satisfy requirement (d). Mandatory 30-day expiration directly contradicts NIST SP 800-63B §5.1.1.2 guidance against routine password aging. **D**, A shared biometric account is technically and logistically problematic, most biometric systems enroll individuals, not roles, and a shared account still fails requirement (a) for individual accountability.*